

RAPPORT DE SÉCURITÉ

ORTHRUS

Rapport de Tests d'Intrusion API

Cible:

<https://example.com>

Date du Scan: 2026-06-05 08:45:39

Avertissement Légal & Confidentialité

Ce rapport est STRICTEMENT CONFIDENTIEL et sa distribution est soumise à restriction. Il est destiné uniquement au personnel autorisé. Il est généré par un outil automatisé de test de sécurité (Orthrus). L'outil assigne un score CVSS de Base théorique qui peut ne pas refléter le contexte environnemental ou temporel de la vulnérabilité. Les auteurs et l'outil lui-même déclinent toute responsabilité en cas de vulnérabilité non détectée, de failles critiques manquées, ou de compromissions ultérieures des systèmes testés. Cet outil est fourni exclusivement pour des tests de sécurité autorisés et encadrés.

Méthodologie et Critères d'Évaluation

Ce rapport présente les résultats d'une analyse automatisée de sécurité dynamique (DAST). L'analyse a consisté à envoyer divers payloads malveillants et des entrées inattendues à l'API cible afin d'identifier les vulnérabilités de sécurité.

Méthodologies et Standards

Standard	Application
OWASP API Security Top 10	Classification des vulnérabilités spécifiques aux API et directives de test
OWASP Top 10 (2021)	Framework principal de classification des vulnérabilités web
CVSS v3.1	Système commun d'évaluation des vulnérabilités pour une notation objective de la criticité
CWE / CAPEC	Énumération des faiblesses communes et suivi des modèles d'attaque
Évaluation DAST Automatisée	Injection dynamique de payloads, fuzzing et évaluation des états authentifiés/non-authentifiés

Définition de la Note de Sécurité

- A** Excellente posture de sécurité. Aucune vulnérabilité élevée ou critique détectée.
- B** Bonne posture de sécurité. Des vulnérabilités mineures sont présentes, mais aucune menace critique immédiate.
- C** Posture de sécurité passable. Plusieurs vulnérabilités moyennes ou une seule vulnérabilité élevée nécessitent une attention particulière.
- D** Médiocre posture de sécurité. Plusieurs vulnérabilités élevées détectées. Une correction urgente est nécessaire.
- F** Échec critique. Une ou plusieurs vulnérabilités critiques détectées, exposant l'application à des risques immédiats et sévères.

1. Résumé Global

NOTE GLOBALE DE RISQUE

D

STATISTIQUES CLÉS

7

TOTAL DES VULNÉRABILITÉS

0

CRITIQUE

1

ÉLEVÉ

0

MOYEN

6

FAIBLE

0

INFO

CRITIQUE: Les vulnérabilités critiques indiquent une menace grave et immédiate pour la sécurité de l'application. Elles peuvent généralement être exploitées sans authentification et entraîner une compromission totale du système ou une fuite de données majeure. Une correction immédiate est requise.

ÉLEVÉ: Les vulnérabilités de niveau élevé représentent une menace significative. Elles nécessitent souvent un certain niveau d'accès ou une exploitation complexe, mais peuvent entraîner un vol de données majeur ou une perturbation du système. Elles doivent être traitées en priorité haute.

MOYEN: Les vulnérabilités moyennes représentent une menace modérée. Elles nécessitent généralement des conditions préalables spécifiques ou un accès autorisé pour être exploitées. Elles doivent être corrigées lors de la prochaine mise à jour.

FAIBLE: Les vulnérabilités faibles ont un impact minime. Elles peuvent exposer des informations non sensibles ou nécessiter des scénarios très improbables pour être exploitées. Elles doivent être traitées lorsque les ressources le permettent.

INFO: Les observations informatives ne représentent pas une vulnérabilité directe, mais soulignent des bonnes pratiques de sécurité qui pourraient être améliorées pour renforcer la posture globale.

2. Résumé des Vulnérabilités

Chaque découverte est notée sous CVSS v3.1 (pour la parité avec NVD, CISA KEV et la plupart des avis des fournisseurs) et CVSS v4.0 (norme FIRST actuelle depuis novembre 2023). Les bandes de sévérité sont identiques pour les deux versions. Les entrées détaillées incluent les vecteurs complets v3.1 et v4.0. Les scores reflètent ce qui a été enregistré lors de l'évaluation initiale ; les vecteurs sont documentés pour la reproductibilité par rapport au calculateur CVSS du FIRST.

Distribution des Sévérités

Sévérité	Nombre	Plage CVSS (v3.1 / v4.0)	Priorité de Correction
CRITIQUE	0	9.0 to 10.0	Immédiate (avant la prochaine version)
ÉLEVÉ	1	7.0 to 8.9	Dans 1 cycle de sprint
MOYEN	0	4.0 to 6.9	Dans 2 cycles de sprint
FAIBLE	6	0.1 to 3.9	Prochaine revue trimestrielle
INFO	0	0.0	Recommandation de bonne pratique

3. Résultats Détaillés

Cleartext Transmission of Sensitive Information

Sévérité:

ÉLEVÉ

Score CVSS de Base: CWE: CWE_319

7.4

Référence CAPEC: CAPEC-94

OWASP: A04:2025 - Cryptographic Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://example.com>

Description

The API endpoint is exposed over unencrypted HTTP. Data sent and received can be intercepted.

Preuve

Endpoint was accessed over HTTPS but successfully responded to HTTP (port 80) without a redirect to HTTPS.

Requête :

```
GET http://example.com
```

Réponse :

```
No Response
```

Remédiation

Ensure all API endpoints are exclusively accessible via HTTPS. Implement HSTS (HTTP Strict Transport Security) and enforce 301/302 redirects from HTTP to HTTPS.

Missing Security Header: HSTS

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://example.com>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Preuve

Header 'Strict-Transport-Security' is missing from the response.

Requête :

```
GET https://example.com
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all nulls.

Missing Security Header: X-Content-Type-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://example.com>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Preuve

Header 'X-Content-Type-Options' is missing from the response.

Requête :

```
GET https://example.com
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all nulls.

Missing Security Header: X-Frame-Options

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_1021

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://example.com>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Preuve

Header 'X-Frame-Options' is missing from the response.

Requête :

```
GET https://example.com
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'X-Frame-Options' header in all nulls.

Missing Security Header: CSP

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://example.com>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Preuve

Header 'Content-Security-Policy' is missing from the response.

Requête :

```
GET https://example.com
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all nulls.

Missing Security Header: Permissions-Policy

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Terminaison: GET <https://example.com>

Description

The HTTP response does not contain the 'Permissions-Policy' security header.

Preuve

Header 'Permissions-Policy' is missing from the response.

Requête :

```
GET https://example.com
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Permissions-Policy' header in all nulls.

Missing Security Header: Referrer-Policy

Sévérité:

FAIBLE

Score CVSS de Base: CWE: CWE_693

4.3

Référence CAPEC: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Point de Termination: GET <https://example.com>

Description

The HTTP response does not contain the 'Referrer-Policy' security header.

Preuve

Header 'Referrer-Policy' is missing from the response.

Requête :

```
GET https://example.com
```

Réponse :

```
No Response
```

Remédiation

Configure your web server or application framework to include the 'Referrer-Policy' header in all nulls.